

Part 1: The Initial Discovery & Risk Triage

Task 1.1 — The Whistleblower Email

Allegation A: Improper EU-US Data Transfers

Primary Regulation/Framework at Risk: General Data Protection Regulation (GDPR), specifically Chapter V, which governs the transfer of personal data to third countries.

Potential Legal Implication: Administrative fines of up to €20 million or 4% of GlobalSync's total annual global turnover, whichever is higher. Additionally, the CNIL (French Data Protection Authority) or any EU supervisory authority could issue an order to immediately suspend all data transfers, which would effectively shut down GlobalSync's EU operations.

Key Dimension: This non-compliance is Unintentional and Systemic. There is no evidence of deliberate wrongdoing. Rather, GlobalSync's rapid growth outpaced its compliance infrastructure, and no legal transfer mechanism was ever established. Because this affects the entire EU-US data flow across the organisation, it is systemic, not an isolated incident.

Allegation B: Bribery of Government Officials in Brazil

Primary Regulation/Framework at Risk: The Foreign Corrupt Practices Act (FCPA), a US federal law that prohibits US companies and their subsidiaries from bribing foreign government officials. Additionally, Brazil's Lei 12.846/2013 (the Clean Company Act), Brazil's own anti-corruption law, which holds companies strictly liable for corrupt acts committed on their behalf.

Potential Legal Implication: Criminal liability for both the company and the individual executives involved. This includes substantial financial penalties, disgorgement of profits made from the corrupt contracts, and potential imprisonment of responsible individuals. A DOJ or SEC investigation could also trigger debarment, preventing GlobalSync from doing business with government entities.

Key Dimension: This non-compliance is Intentional and Isolated. The sales team in Brazil appears to have made a deliberate decision to offer "incentives" to secure contracts. It is isolated because it appears confined to one regional sales team, rather than being a company-wide practice.

Allegation C: Failure to Process Data Deletion Requests

Primary Regulation/Framework at Risk: GDPR — specifically Article 17, the "Right to Erasure" (also known as the Right to be Forgotten). Additionally, the California Consumer Privacy Act/California Privacy Rights Act (CCPA/CPRA) — which grants California residents the right to request deletion of their personal data.

Potential Legal Implication: Regulatory fines under GDPR (up to €20 million or 4% of global turnover) and civil lawsuits under CCPA/CPRA, where consumers have a private right of action. The reputational damage from a class-action lawsuit could also jeopardise the pending merger.

Key Dimension: This non-compliance is Unintentional and Systemic. There is no centralised process for handling Data Subject Requests (DSRs) across the organisation. This is a structural failure, not one employee's mistake, meaning every department that receives deletion requests is affected.

Allegation D: Ineffective Financial Reporting Controls

Primary Regulation/Framework at Risk: The Sarbanes-Oxley Act (SOX) — specifically Section 404, which requires management to assess and certify the effectiveness of internal controls over financial reporting (ICFR), and requires external auditors to attest to that assessment.

Potential Legal Implication: SEC enforcement action, criminal liability for the CEO and CFO who sign off on financial statements (up to 20 years imprisonment under SOX Section 906 for wilful certification of false reports), and significant financial penalties. This could also trigger investor lawsuits and stock price collapse if the company is publicly listed.

Key Dimension: This non-compliance is Unintentional and Systemic. GlobalSync's compliance programs have not kept pace with the company's rapid growth. The lack of effective controls is most likely a result of negligence and under-investment in internal audit infrastructure, rather than deliberate financial fraud.

Task 1.2 — Risk Assessment Matrix

	Insignificant	Minor	Moderate	Major	Catastrophic
Almost Certain	Medium	Medium	High	High	Critical (A) (C)
Likely	Low	Medium	High	High (B, D)	Critical
Possible	Low	Low	Medium	High	High
Unlikely	Low	Low	Medium	Medium	High
Rare	Low	Low	Low	Medium	Medium

Justification for Each Allegation

Allegation A — EU-US Data Transfers (GDPR)

Likelihood: Almost Certain | Impact: Catastrophic | Risk Level: CRITICAL

Financial Impact: GlobalSync faces fines of up to €20 million or 4% of total global annual turnover, whichever is higher, a potentially devastating financial penalty.

Legal Impact: The CNIL has already issued a formal inquiry. Regulators could order an immediate suspension of all EU-US data transfers, effectively shutting down GlobalSync's EU operations.

Reputational Impact: A public enforcement action by a European regulator would severely damage GlobalSync's credibility with EU clients and could cause the European merger partner to withdraw from the pending deal entirely.

Allegation B — Bribery in Brazil (FCPA + Lei 12.846)

Likelihood: Likely | Impact: Major | Risk Level: HIGH

Financial Impact: GlobalSync faces substantial financial penalties under both the FCPA and Brazil's Lei 12.846, including disgorgement of all profits earned from the corrupt contracts.

Legal Impact: The DOJ has already begun a criminal investigation. Individual sales executives face potential imprisonment, and the company could face debarment from future government contracts.

Reputational Impact: A bribery scandal, especially one involving government officials, would severely damage GlobalSync's public image, erode client trust, and raise serious concerns for the merger partner about the company's ethical culture.

Allegation C — Ignored Data Deletion Requests (GDPR + CCPA/CPRA)

Likelihood: Almost Certain | Impact: Catastrophic | Risk Level: Critical

Financial Impact: GlobalSync faces simultaneous GDPR administrative fines of up to €20 million or 4% of global turnover and active civil liability from a class action lawsuit already filed in California under CCPA/CPRA. The dual-jurisdiction financial exposure across the EU and United States makes the combined financial impact potentially catastrophic.

Legal Impact: The violation has already been confirmed internally, 40% of deletion requests were never actioned. Regulatory enforcement and court proceedings are therefore almost certain.

Reputational Impact: A class-action lawsuit is public by nature. Media coverage of a company ignoring customers' rights to delete their data would seriously damage GlobalSync's brand, particularly among privacy-conscious EU and US clients.

Allegation D — Weak Financial Reporting Controls (SOX)

Likelihood: Likely | Impact: Major | Risk Level: HIGH

Financial Impact: SEC enforcement actions carry heavy financial penalties. Additionally, if the merger partner discovers weak financial controls during due diligence, they may reprice or cancel the deal, costing GlobalSync the entire transaction value.

Legal Impact: Under SOX Section 404 and Section 906, the CEO and CFO face personal criminal liability for certifying financial statements without adequate internal controls, including potential imprisonment of up to 20 years.

Reputational Impact: Investor confidence would collapse if SOX violations became public, causing stock price damage and signalling to the market that GlobalSync's financial reporting cannot be trusted.

Task 2.1 — Scoping the Audit

Audit Scope

The scope of this audit covers all business units, processes, data flows, and financial controls relevant to the four allegations raised by the whistleblower. Specifically, the following areas are in scope:

Business Units Under Review:

- **IT/Engineering Department** — responsible for managing data servers, data flows, and technical execution of data deletion requests
- **Legal and Compliance Department** — responsible for establishing legal transfer mechanisms, data privacy policies, and anti-corruption compliance programs
- **Sales Department (Brazil)** — responsible for government contract procurement and client relationship management
- **Finance and Accounting Department** — responsible for financial reporting, approval of payments, and internal controls
- **Customer Support Department** — responsible for receiving and logging customer data deletion requests
- **Internal Audit Department** — responsible for testing and certifying the effectiveness of internal financial controls
- **Senior Management and Board of Directors** — responsible for governance structure, tone at the top, and oversight of all compliance obligations

Geographic Scope: All GlobalSync operations in the United States, the European Union, and Brazil are included within the scope of this audit.

Audit Objectives

The objectives of this audit are to:

1. Determine whether GlobalSync has a valid legal mechanism in place for transferring EU personal data to its US data center in compliance with GDPR Chapter V
2. Determine whether GlobalSync's sales team in Brazil engaged in improper payments or incentives to secure government contracts in violation of the FCPA and Lei 12.846
3. Determine whether GlobalSync has a formal, documented process for receiving, tracking, and actioning customer data deletion requests in compliance with GDPR Article 17 and CCPA/CPRA
4. Determine whether GlobalSync's internal controls over financial reporting are effective and compliant with SOX Section 404

Key Audit Questions

Allegation A — EU-US Data Transfers:

- Does GlobalSync have a valid legal mechanism in place for transferring EU personal data to its US data center?
- Has GlobalSync conducted a data mapping exercise to identify all personal data flows between the EU and the US?
- Is there documented evidence that the Legal and Compliance team reviewed and approved the current data transfer arrangement?

Allegation B — Bribery in Brazil:

- Can GlobalSync demonstrate that all government contracts in Brazil were secured through legitimate means, free from improper payments or incentives?
- Is there a formal anti-bribery and anti-corruption policy in place, and has the Brazil sales team been trained on it?
- Are all payments and incentives offered to clients subject to a formal approval process?

Allegation C — Ignored Data Deletion Requests:

- Does GlobalSync have a formal, documented process for receiving, tracking, and actioning customer data deletion requests in compliance with GDPR Article 17 and CCPA/CPRA?
- Is there a centralized system for logging and monitoring the status of all data subject requests?
- Can GlobalSync demonstrate that deletion requests are being completed within the legally required timeframe?

Allegation D — Weak Financial Reporting Controls:

- How does GlobalSync demonstrate that its internal controls over financial reporting are effective and compliant with SOX Section 404?

- Has management completed a formal assessment of internal control effectiveness within the last financial year?
- Is there documented evidence that identified control weaknesses have been escalated to the Board and remediated?

Evidence Gathering Plan

Document Review

The following three documents would be requested first:

Document 1: Data Transfer Policy

This document would be requested to determine whether GlobalSync has a formally documented and board-approved policy governing the transfer of personal data from the European Union to the United States. The absence of this document would itself constitute evidence of a compliance failure, as it would indicate that no legal transfer mechanism was ever formally established or communicated across the organisation.

Document 2: Data Processing Agreement (DPA)

This document would be requested to determine whether a legally binding contract exists between GlobalSync's EU operations and its US data center, outlining the terms under which EU personal data is transferred and processed. Under GDPR, a Data Processing Agreement is a mandatory requirement where personal data is shared between a data controller and a data processor. The absence of this agreement would confirm that EU-US data transfers are occurring without a valid legal basis.

Document 3: Data Map / Data Flow Inventory

This document would be requested to obtain a comprehensive overview of all personal data held by GlobalSync, including where it originates, where it is stored, where it is transferred, and who has access to it. A Data Flow Inventory would allow the audit team to identify all EU-US data transfer pathways and determine whether each one is covered by a valid legal mechanism.

Interviews

The following three job roles would be interviewed:

Interview 1: IT Manager

The IT Manager is responsible for the technical infrastructure that facilitates data transfers between GlobalSync's EU and US systems. They would have direct knowledge of how data flows are configured and whether any technical controls exist to restrict unauthorised transfers.

Key Questions:

- Can you describe how personal data from EU clients is currently transferred to and stored in the US data center, and what technical controls are in place to manage this process?
- Have you ever received instructions from the Legal or Compliance team to implement restrictions or safeguards on EU-US data transfers, and if so, can you show evidence of those instructions?

Interview 2: Data Privacy Manager

The Data Privacy Manager is responsible for the day-to-day management of GDPR compliance across the organisation. They would have direct knowledge of whether data privacy policies exist, whether staff have been trained, and whether any legal transfer mechanisms have been put in place.

Key Questions:

- Does GlobalSync currently have a valid legal mechanism in place for transferring EU personal data to the US, such as Standard Contractual Clauses or a binding corporate rule, and can you provide documentation of this?
- Has GlobalSync conducted a Transfer Impact Assessment to evaluate the risks of transferring EU personal data to the US, and if so, when was this last reviewed?

Interview 3: Data Protection Officer (DPO)

Under GDPR Article 37, companies that process large volumes of EU personal data are required to appoint a Data Protection Officer. The DPO is legally responsible for ensuring GDPR compliance and serves as the primary point of contact with supervisory authorities such as the CNIL. They would have the most authoritative knowledge of whether legal transfer agreements were ever established.

Key Questions:

- Has GlobalSync ever formally assessed its EU-US data transfer arrangements for GDPR compliance, and what was the outcome of that assessment?
- Have you ever raised concerns with senior management or the Board about the absence of a valid legal mechanism for EU-US data transfers, and if so, what was the response?

Control Test

Test: Verification of EU-US Data Transfer Mechanism

To physically verify whether a valid legal mechanism exists for EU-US data transfers, the audit team would perform the following control test:

Step 1: Request a live demonstration from the IT department of how EU client data is routed from GlobalSync's EU servers to its US data center, including a review of system architecture diagrams and network configuration logs.

Step 2: Cross-reference the data flows identified in the demonstration against the Data Flow Inventory to confirm that all EU-US transfer pathways have been formally documented.

Step 3: For each identified transfer pathway, verify whether a corresponding legal mechanism exists, such as Standard Contractual Clauses (SCCs), Binding Corporate Rules (BCRs), or an adequacy decision, by reviewing signed agreements and legal documentation.

Step 4: Where a legal mechanism is claimed to exist, verify its validity by checking that it has been properly executed, is current, and has not been invalidated by any subsequent regulatory ruling such as the Schrems II decision.

Expected Outcome: If no valid legal mechanism can be produced for any identified EU-US data transfer pathway, this constitutes confirmed evidence of a GDPR Chapter V violation, supporting the whistleblower's allegation.

Task 2.3: Drafting the Audit Finding

Allegation C: Failure to Process Data Subject Deletion Requests

Condition

GlobalSync Inc. has no formal, documented process for receiving, tracking, and actioning customer data deletion requests. A sample review conducted during the audit revealed that 40% of data deletion requests submitted by customers were never actioned. There is no centralised system in place for logging, monitoring, or escalating Data Subject Requests (DSRs), meaning that deletion requests are routinely lost, ignored, or forgotten across the organisation.

Criteria

Under **GDPR Article 17 (Right to Erasure)**, GlobalSync is legally required to action data deletion requests without undue delay and within one month of receiving the request. Where requests are complex or numerous, this period may be extended by a further two months, but the customer must be informed. The regulation further requires that organisations have a formal process in place to receive, track, and action such requests consistently and reliably.

Similarly, under the California Consumer Privacy Act / California Privacy Rights Act (CCPA/CPRA), GlobalSync is required to comply with verified consumer deletion requests within 45 days. An extension of a further 45 days is permitted where necessary, provided the consumer is notified. Both regulations place a clear legal obligation on GlobalSync to maintain a structured and auditable process for handling all Data Subject Requests.

Cause

The root cause of this non-compliance is threefold:

- 1. Absence of a formal process:** GlobalSync has never established a formal, documented procedure for receiving, logging, tracking, and actioning data deletion requests. No standard operating procedure exists, and no department has been formally assigned ownership of this obligation.
- 2. No centralised tracking system:** There is no centralised system or technology platform in place to log incoming deletion requests, assign them to responsible individuals, track their progress, or escalate overdue requests. As a result, requests received across different departments are handled inconsistently or not at all.
- 3. Rapid organisational growth:** GlobalSync's compliance infrastructure has not kept pace with the company's rapid expansion into multiple jurisdictions. The organisation scaled its operations significantly without a corresponding investment in data privacy processes, tools, or staffing.

Effect

The consequences of this non-compliance are severe across three dimensions:

Financial Impact: GlobalSync is exposed to administrative fines of up to €20 million or 4% of total annual global turnover under GDPR, whichever is higher. Simultaneously, the company faces significant civil liability arising from the class action lawsuit already filed in California under CCPA/CPRA, which could result in statutory damages for each affected consumer.

Legal Impact: A class action lawsuit has already been filed in California on behalf of all users whose deletion requests were ignored. Regulatory enforcement action by EU supervisory authorities is also highly probable given the confirmed nature of the violation. GlobalSync now faces simultaneous legal proceedings on two fronts, in the EU and in the United States.

Reputational Impact: Public awareness of this violation through media coverage of the class action lawsuit will severely damage GlobalSync's reputation among existing and prospective clients. Clients who entrust GlobalSync with their data will lose confidence in the company's ability to protect their privacy rights and will seek alternative providers. Most critically, the European merger partner will likely conduct due diligence and discover both the violation and the active lawsuit, putting the entire merger deal at serious risk.

Risk Rating

HIGH

This finding is rated High because the violation has already been confirmed through internal audit, a class action lawsuit is actively in progress, and regulatory enforcement action is almost

certain. The financial, legal, and reputational consequences are severe and will worsen significantly if immediate remediation action is not taken. The rating stops short of Critical because the violation, while serious, is containable, GlobalSync can implement a formal Data Subject Request process, demonstrate good faith to regulators, and potentially negotiate reduced penalties through proactive cooperation. However, urgent action is required to prevent this escalating to a Critical rating.

Task 3.1: The Regulator Knocks

Following the Schrems II ruling by the Court of Justice of the European Union in 2020, which invalidated the EU-US Privacy Shield agreement, GlobalSync must rely on one of the following legally recognised mechanisms to transfer EU personal data to the United States:

Mechanism 1: Standard Contractual Clauses (SCCs)

Standard Contractual Clauses are pre-approved legal contracts issued by the European Commission that must be signed between the data exporter (GlobalSync EU) and the data importer (GlobalSync US). They contractually bind both parties to uphold GDPR-level data protection standards regardless of where the data is processed. SCCs are currently the most commonly used transfer mechanism globally due to their accessibility and flexibility. However, following Schrems II, companies using SCCs must also conduct a Transfer Impact Assessment (TIA) to verify that US law does not undermine the protections promised in the clauses.

Mechanism 2: Binding Corporate Rules (BCRs)

Binding Corporate Rules are internal data protection policies formally approved by an EU supervisory authority that allow multinational companies to transfer personal data within their corporate group across borders. BCRs are legally robust but require significant time and resources to develop and obtain regulatory approval, making them less practical for companies that need an immediate solution.

Mechanism 3: EU-US Data Privacy Framework (DPF)

The EU-US Data Privacy Framework is a new adequacy agreement between the European Union and the United States, adopted in 2023, which replaced the invalidated Privacy Shield. It establishes that the United States provides an adequate level of protection for EU personal data, subject to compliance with the framework's principles. This is currently the most robust and reliable mechanism available for EU-US data transfers.

The Most Robust Mechanism and What GlobalSync Must Do

The EU-US Data Privacy Framework (DPF) is the most robust legal mechanism available to GlobalSync for the following reasons:

- It has been formally recognised by the European Commission as providing an adequate level of data protection

- It provides greater legal certainty than SCCs, which remain vulnerable to legal challenges
- It includes stronger redress mechanisms for EU data subjects whose rights are violated
- It removes the strict legal requirement for a Transfer Impact Assessment that applies under SCCs, though leading privacy practitioners still recommend conducting one as a precautionary measure given that the DPF itself faces ongoing legal challenges before the Court of Justice of the European Union

To implement the EU-US Data Privacy Framework, GlobalSync must:

Step 1 — Self-Certify with the US Department of Commerce: GlobalSync must formally register with the US Department of Commerce and publicly commit to complying with the framework's data protection principles, including purpose limitation, data minimisation, and security requirements.

Step 2 — Update Privacy Policies: GlobalSync must update its public-facing privacy policies to explicitly state that the company participates in the EU-US Data Privacy Framework and describe how EU personal data is protected under the framework.

Step 3 — Conduct a Transfer Impact Assessment (TIA): GlobalSync must assess whether US surveillance laws or other legal obligations could undermine the data protection commitments made to EU data subjects under the framework.

Step 4 — Implement Technical and Organisational Safeguards: GlobalSync must put in place appropriate technical measures — such as encryption and access controls — and organisational measures — such as staff training and data handling procedures — to protect EU personal data throughout the transfer process.

Step 5 — Establish Redress Mechanisms: GlobalSync must provide EU citizens with accessible and effective means to raise complaints if they believe their data protection rights have been violated, including access to an independent dispute resolution mechanism.

Question 2: If found in violation, what is the maximum potential fine GlobalSync could face from the CNIL under GDPR?

Maximum Potential Fine from the CNIL

If found in violation of GDPR's data transfer requirements, GlobalSync faces the maximum administrative fine available under **GDPR Article 83(5)**, which is:

€20 million or 4% of GlobalSync's total annual global turnover, whichever is higher.

In addition to the financial penalty, the CNIL has the authority to issue an order immediately suspending all EU-US data transfers, which would effectively shut down GlobalSync's EU

operations entirely. This would not only cause severe operational disruption but would also almost certainly collapse the pending merger with the European company, as no acquirer would proceed with a target whose EU operations have been suspended by a regulator.

Task 3.2: The Lawsuit

Question: Under which California law (CCPA/CPRA) does this lawsuit fall? What specific "consumer right" has been violated?

The class action lawsuit falls under the California Consumer Privacy Act (CCPA) as amended by the California Privacy Rights Act (CPRA).

The specific consumer right that has been violated is the Right to Delete.

Under CCPA/CPRA, California residents have the legal right to request that a business delete personal information it has collected about them. Upon receiving a verified deletion request, the business is legally obligated to:

- Delete the consumer's personal information from its own records
- Direct any service providers or third parties to whom the data was disclosed to also delete the information
- Confirm to the consumer that the deletion has been completed
- Comply with the request within 45 days of receipt, with a possible extension of a further 45 days where necessary, provided the consumer is notified

GlobalSync failed to action 40% of deletion requests and had no formal process in place for receiving, tracking, or actioning such requests. This constitutes a direct and confirmed violation of the consumer's Right to Delete under CCPA/CPRA.

Question 2: What is a key difference between the private right of action in the CCPA/CPRA vs. the GDPR?

The key difference between the two frameworks lies in who can take legal action and when.

Under CCPA/CPRA:

Individual consumers have a direct private right of action, meaning they can personally file a lawsuit against a company in court without first waiting for a regulator to investigate or act. This right is specifically available where a data breach has exposed a consumer's non-encrypted or non-redacted personal information due to the company's failure to implement reasonable security measures. In the case of other violations, such as ignored deletion requests, the California Attorney General has the authority to investigate and bring enforcement action against the company on behalf of consumers. These are two separate but complementary enforcement paths that make CCPA/CPRA a powerful consumer protection tool.

Under GDPR:

Individual consumers do not have a direct private right of action in the same way. Under GDPR, an individual who believes their data rights have been violated must first file a formal complaint with the relevant supervisory authority, such as the CNIL in France or the ICO in the United Kingdom. The supervisory authority then investigates the complaint and decides whether to take enforcement action against the company. While GDPR does allow individuals to seek compensation through national courts for material and non-material damages, this process is slower and more dependent on regulatory involvement than the CCPA/CPRA approach.

Task 3.3 — The Settlement Dilemma

Question: What is a DPA, and what are the two key benefits for GlobalSync in accepting it?

A Deferred Prosecution Agreement is a formal legal arrangement between the Department of Justice (DOJ) and a company that has been charged with a criminal offence. Under a DPA, the DOJ agrees to formally pause or defer criminal prosecution against the company for an agreed period of time, typically between two and three years. During this period, the company must fulfil a set of specific obligations stipulated in the agreement. If the company successfully complies with all obligations within the agreed timeframe, the DOJ drops all criminal charges entirely. If the company fails to comply, the DOJ reserves the right to resume full criminal prosecution.

A DPA is essentially a second chance agreement, it gives a company the opportunity to demonstrate genuine commitment to reform without suffering the full consequences of a criminal conviction.

Two Key Benefits for GlobalSync in Accepting the DPA:

Benefit 1 — Avoidance of Criminal Conviction: By accepting the DPA, GlobalSync avoids a full criminal trial and the permanent reputational damage associated with a public criminal conviction. A criminal conviction would result in a permanent criminal record for the company, potential imprisonment of senior executives involved in the bribery scheme, and possible debarment from future government contracts globally. The DPA allows GlobalSync to resolve the matter without any of these catastrophic consequences, provided it fulfills its obligations.

Benefit 2 — Continuity of Business Operations and Preservation of the Merger: By accepting the DPA, GlobalSync can continue operating as a going concern without the disruption of a prolonged criminal trial. This is particularly critical given the pending merger with a European company scheduled in six months. A full criminal prosecution would almost certainly cause the merger partner to withdraw from the deal entirely. The DPA allows GlobalSync to demonstrate to the merger partner that the matter is being resolved responsibly and that the company is committed to reforming its compliance culture, significantly improving the chances of the merger proceeding as planned.

Question 2: What is one major obligation the company will likely have to fulfill under this DPA

The most significant obligation GlobalSync will likely be required to fulfil under the DPA is the implementation of a comprehensive, court-monitored anti-bribery and anti-corruption compliance program.

This obligation would typically include the following requirements:

1. Development of a Formal Anti-Bribery Policy: GlobalSync must develop and implement a comprehensive written anti-bribery and anti-corruption policy that explicitly prohibits the offering, giving, or receiving of improper payments or incentives in any form, in any jurisdiction where the company operates.

2. Mandatory Staff Training: All employees, particularly those in sales, procurement, and client-facing roles — must complete mandatory anti-bribery and anti-corruption training. This ensures that every individual within the organisation understands their legal obligations under the FCPA and Lei 12.846.

3. Appointment of an Independent Compliance Monitor: The DOJ will likely require GlobalSync to appoint an independent compliance monitor, an external expert approved by the DOJ — who will oversee and report on the company's compliance program for the duration of the DPA. This ensures that the reforms are genuine and not superficial.

4. Disgorgement of Profits: GlobalSync will likely be required to pay back all profits earned from government contracts that were secured through corrupt means. This financial penalty ensures that the company does not benefit from its wrongdoing.

5. Regular Reporting to the DOJ: GlobalSync must provide regular progress reports to the DOJ demonstrating that it is meeting its obligations under the DPA, including evidence of policy implementation, training completion, and internal audit findings.

Task 4.1: The Remediation Plan

Corrective Action Plan (CAP). Allegation C: Failure to Process Data Subject Deletion Requests

Specific Action Item	Assigned Department/Owner	Target Completion Date	Metric for Success
Draft and approve a formal Data Subject Request (DSR) Policy that defines the legal obligations, responsibilities, and procedures for receiving, processing, and completing	Legal and Compliance Department / Data Protection Officer (DPO)	2 weeks	Zero DSR-related regulatory complaints or legal actions are filed against GlobalSync in the 90 days following policy

customer deletion requests in compliance with GDPR Article 17 and CCPA/CPRA			approval, confirming the policy is operational and not merely documented
Design and implement a formal, documented Standard Operating Procedure (SOP) for receiving, logging, tracking, and actioning data deletion requests, with a clearly assigned department owner responsible for each stage of the process	Legal and Compliance Department in collaboration with IT and Customer Support	1 month	A fully documented SOP exists, has been approved by the DPO, and has been communicated to all relevant departments
Procure and implement a centralised Data Subject Request (DSR) Management Platform to receive, assign, track, and escalate all incoming deletion requests, with automatic reminders for requests approaching their legal deadline	IT/Engineering Department	3 months	Zero deletion requests exceed the 30-day GDPR or 45-day CCPA legal deadline within 90 days of platform implementation, confirmed by monthly DPO compliance reports to the Board.
Conduct mandatory company-wide staff training on the new DSR Policy, Standard Operating Procedure, and DSR Management Platform, with particular focus on Customer Support, Legal, IT, and Sales departments	HR in collaboration with Legal and Compliance	4 months	Post-training compliance audit conducted 30 days after training completion confirms that DSR handling error rate has decreased by a minimum of 80% compared to the pre-training baseline, measured through a sample review of 50 randomly selected requests
Conduct an internal audit of all outstanding deletion requests to identify and action any requests that were previously ignored or lost, and report findings to the Board of Directors	Internal Audit Department / Data Protection Officer (DPO)	1 month	All previously ignored deletion requests have been identified, actioned, and confirmed as complete within the legally required timeframe

Notes on Implementation

- All five action items must be completed before month 5 to allow GlobalSync sufficient time to demonstrate genuine compliance to the European merger partner before the deal closes in six months
- The DPO must provide monthly progress reports to the Board of Directors throughout the implementation period
- GlobalSync should consider proactively notifying the relevant supervisory authorities of its remediation plan as a gesture of good faith, which may positively influence any regulatory penalty decisions
- The independent compliance monitor appointed under the DOJ's Deferred Prosecution Agreement should also be kept informed of progress on this CAP

Task 4.2: The Tone at the Top

Ladies and gentlemen of the Board, I stand before you today not to deliver bad news, but to present an opportunity, an opportunity for GlobalSync Inc. to transform its compliance culture from a vulnerability into its greatest competitive advantage.

The findings I will present today are serious. We face regulatory investigations on two continents, an active class action lawsuit in California, a Department of Justice inquiry into our Brazil operations, and significant weaknesses in our financial reporting controls.

These are not isolated incidents, they are symptoms of a compliance infrastructure that has not kept pace with our remarkable growth. However, I want to be unequivocal with this Board: compliance is not a cost center, it is the foundation upon which this company's future survival and prosperity must be built. The pending merger with our European partner makes this moment even more critical. Our merger partner will conduct thorough due diligence, and what they find in the next six months will either seal or shatter the most important deal in this company's history. As the leaders of this organisation, the tone we set in this boardroom today will define GlobalSync's compliance culture tomorrow. Every department, every team, and every employee takes their cue from this room. I am asking this Board to make a clear, unambiguous, and public commitment to compliance, not because regulators are watching, but because it is the right thing to do, because our clients trust us with their most sensitive data, because our employees deserve to work for an ethical organisation, and because our shareholders deserve a company that will still be operating and thriving ten years from now.

The Corrective Action Plan I am presenting today is not just a remediation exercise, it is a strategic investment in GlobalSync's reputation, its relationships, and its long term business survival. We are currently sitting on the edge of a loaded gun, and decisive leadership action today is the only thing that will move us to safety.

I am confident that with the Board's full commitment and support, GlobalSync will not only survive this crisis, it will emerge from it stronger, more trusted, and better positioned for sustainable global growth than ever before.

Bonus Challenge: The Future-Proofing Question

The Strategic Recommendation

If GlobalSync is to avoid a compliance crisis of this magnitude in the future, the single most important emerging trend the Board should invest in immediately is Continuous Auditing. Every single compliance failure uncovered during this assessment could have been detected and prevented earlier if GlobalSync had a Continuous Auditing capability in place.

What is Continuous Auditing?

Continuous Auditing is the use of automated technology and real-time monitoring tools to assess compliance, internal controls, and risk on a daily, or even hourly basis, rather than relying on traditional periodic audits conducted once or twice a year.

Why Continuous Auditing is a Strategic Investment for GlobalSync

The four allegations uncovered during this assessment demonstrate precisely why annual or periodic auditing is insufficient for a fast-growing multinational technology company like GlobalSync. Here is how Continuous Auditing would have prevented each crisis:

Allegation A — Improper EU-US Data Transfers (GDPR)

A Continuous Auditing system with automated data flow monitoring would have detected unauthorised EU-US data transfers in real time the moment they began occurring. Automated alerts would have immediately notified the Legal and Compliance team, allowing them to implement a legal transfer mechanism before the CNIL ever became involved. Instead, the violation went undetected for an extended period, resulting in a formal regulatory inquiry and potential fines of up to €20 million.

Allegation B — Bribery in Brazil (FCPA + Lei 12.846)

A Continuous Auditing system with automated transaction monitoring would have flagged unusual payment patterns in the Brazil sales team, such as unauthorized incentive payments to government officials, the moment they occurred. Automated exception reports would have escalated these transactions to senior management for investigation long before they became a Department of Justice, DOJ matter. Instead, the practice went undetected until a whistleblower came forward.

Allegation C — Ignored Data Deletion Requests (GDPR + CCPA/CPRA)

A Continuous Auditing system integrated with a Data Subject Request management platform would have automatically monitored the status of every deletion request in real time, flagging any request approaching its legal deadline and escalating overdue requests to responsible staff immediately. The 40% non-completion rate that triggered a class action lawsuit would have

been impossible to sustain under continuous monitoring. The system would have caught the first missed request and triggered an immediate corrective response.

Allegation D — Weak Financial Reporting Controls (SOX)

A Continuous Auditing system with automated control testing would have continuously assessed the effectiveness of GlobalSync's internal financial controls, generating real time evidence of control performance for SOX Section 404 compliance. Instead of being unable to prove its controls were effective, GlobalSync would have had a continuously updated, auditable record of control testing results. That record would be available at any time, for regulators, auditors, and merger partners alike

The Business Case for the Board

Investing in Continuous Auditing is not just a compliance decision, it is a strategic business decision for three reasons:

1. Merger Readiness: A Continuous Auditing capability demonstrates to the European merger partner that GlobalSync has mature, sophisticated compliance infrastructure. Due diligence findings showing real time compliance monitoring would significantly increase the merger partner's confidence in GlobalSync as a trustworthy acquisition target.

2. Cost Savings: The combined cost of the GDPR fines, class action lawsuit, DOJ investigation, and reputational damage GlobalSync now faces far exceeds the cost of implementing a Continuous Auditing system. Prevention is always cheaper than cure in compliance.

3. Competitive Advantage: As regulators globally increase their scrutiny of multinational technology companies, organisations with Continuous Auditing capabilities will be able to demonstrate compliance instantly and confidently. This builds trust with clients, regulators, and investors, turning compliance into a genuine competitive differentiator in the marketplace.

Conclusion

Continuous Auditing transforms compliance from a reactive, crisis-driven function into a proactive, intelligence-driven capability. For a fast-growing multinational technology company like GlobalSync, operating across multiple high-risk jurisdictions including the EU, US, and Brazil, it is not a luxury. It is a strategic necessity. The Board's investment in Continuous Auditing today is an investment in GlobalSync's survival, reputation, and long term prosperity tomorrow.

